ML-BOM (Machine Learning Bill of Materials)

Overview

An ML-BOM provides a structured inventory of a machine learning model's components, dependencies, and usage guidelines. This transparency enables security auditing, compliance verification, and supply chain risk assessment.

System Overview

Northstar Assist is an internal question-answering agent for Northstar employees. It is assembled from managed AWS services: an Amazon Bedrock AgentCore Harness runs the agent loop with a foundation model (**Model A**, Anthropic Claude Haiku 4.5), the harness calls one tool through an Amazon Bedrock AgentCore Gateway, and the gateway retrieves passages from an Amazon Bedrock Managed Knowledge Base built over a private S3 bucket holding 30 synthetic company documents. A second model (**Model B**, Amazon Titan Text Embeddings V2) is never called by the agent itself. The Managed KB uses it to embed every document chunk at ingestion time and every search query at retrieval time.

The ML-BOM template describes one model, but this system has two models plus supporting components that shape what the agent can say and leak. Sections 1 to 3 of the template are therefore repeated once per model (Model A, Model B), section 4 inventories the supporting components and the IAM roles by name, and section 5 lists the findings that matter for a launch decision. Identifiers such as the bucket, KB ID and role names come from the deployed resources.

Component data flow

There are two data paths. The **query path** runs on every employee question: the message reaches the harness (trust boundary TB1), the harness sends the conversation to Model A (TB2), Model A decides to call the Retrieve tool, the harness calls the Gateway tool (TB3), the Gateway asks the Managed KB, the KB embeds the query with Model B, searches its vector store and returns the best passages with their S3 source URIs, and those passages enter Model A's context (TB4) before Model A writes a grounded answer. The **ingestion path** runs only when someone syncs the KB: documents are read from S3, chunked, embedded with Model B and written to the vector store. The S3 write path is the fifth trust boundary (TB5) because whatever is stored there can later be retrieved as context.

A Bedrock Guardrail is attached to the harness's model calls and evaluates the user input and the model output. The guardrail's prompt-attack filter does not inspect the retrieved passages that come back as tool results, which is why indirect prompt injection through documents is tracked as an open risk (finding F-07). CloudWatch Logs and Bedrock model-invocation logging record prompts and responses, including any personal data the agent retrieved.

```
Employee → Harness → Gateway tool → AgentCore Gateway → Managed KB → S3
```

```
Query path (every question)
  Employee (Streamlit app or CLI client)                    TB1
    → AgentCore Harness: agent loop, system prompt, memory off
    → Model A: Claude Haiku 4.5 via US inference profile    TB2
    → Gateway tool: MCP Retrieve, IAM (SigV4) inbound       TB3
    → AgentCore Gateway
    → Managed KB: query embedded by Model B (Titan V2)
    → vector store, top chunks with S3 source URIs
    ← chunks return as a tool result into Model A context   TB4
    ← grounded answer, with the source document named

Ingestion path (on KB sync)
  S3 bucket → Managed KB (parse, chunk, embed with Model B) → vector store   TB5
```

Request path

1. The employee asks a question in the Streamlit app or the CLI test client. The app protects access with a shared password, so no per-user identity reaches AWS. It calls InvokeHarness as a single IAM caller.

2. The harness builds the prompt from the course system prompt and the conversation turns. The Bedrock Guardrail evaluates the user input.

3. Model A (Claude Haiku 4.5, reached through the US cross-Region inference profile) decides whether it needs knowledge and, if so, emits a tool call to Retrieve with a search query.

4. The harness signs a request to the AgentCore Gateway with its execution role AmazonBedrockAgentCoreHarnessDefaultServiceRole-37uao (IAM inbound authorization on the Gateway arn:aws:bedrock-agentcore:us-east-1:609617804976:gateway/northstar-assist-gateway-hd1uvsa8f3).

5. The Gateway queries the Managed KB WUWHZC06MP using its service role AmazonBedrockAgentCoreGatewayDefaultServiceRole1791659264711. The KB embeds the query with Model B (1024-dimension vector), searches the vector store and returns the top passages with S3 source URIs and relevance scores.

6. The passages return to the harness as a tool result and are added to Model A's context. They are untrusted data, but the model reads them like any other context.

7. Model A writes the answer and names its source document. The guardrail evaluates the output (sensitive information handling, denied topics, contextual grounding).

8. The response streams back to the employee. The full prompt and response are written to CloudWatch Logs by model-invocation logging and by the harness runtime log group.

Ingestion path

Documents are uploaded to the private bucket northstar-assist-kb-5ca661ad (public access blocked, SSE-S3, versioning on). A KB sync job, run with the KB service role AmazonBedrockExecutionRoleForKnowledgeBase_x7ne0, reads each object, parses the six file formats (csv, docx, html, pdf, txt, xlsx), chunks the text, embeds each chunk with Model B and stores the vectors and chunk text in the managed vector store. Anything that can write to the bucket and start a sync can change what the agent says.

Model A: Anthropic Claude Haiku 4.5 (foundation model)

Model A is the generative model. It reads the system prompt, the conversation and the retrieved passages, decides when to call the Retrieve tool and writes the final answer. It is consumed only as a managed API through the Amazon Bedrock cross-Region inference profile us.anthropic.claude-haiku-4-5-20251001-v1:0.

Model A – 1. Model Information

Field	Value
Name	Claude Haiku 4.5
Version	20251001 (Bedrock model ID suffix v1:0)
Type	text-generation: decoder-only transformer large language model with tool use
Author	Anthropic
Licenses	Proprietary. Anthropic commercial terms and AWS Service Terms apply through Amazon Bedrock. No weights are distributed.
Libraries	N/A (managed API; no libraries or weights are shipped to Northstar)
Source URL	https://aws.amazon.com/bedrock/anthropic/
Model ID (inference profile)	us.anthropic.claude-haiku-4-5-20251001-v1:0
Configured in the harness as	us.anthropic.claude-haiku-4-5-20251001-v1:0
Access path	Amazon Bedrock Runtime, called by the AgentCore Harness under its execution role
Context window	200,000 tokens (max output 64K), per the Amazon Bedrock model card
Knowledge cutoff	February 2025 (Amazon Bedrock model card)
Lifecycle	Active; launched 16 Oct 2025; EOL no sooner than 16 Oct 2026 (Bedrock model card, checked 8 Oct 2026)

Model A – 1.1 BOM Generation (Optional)

Field	Value
Generated Date	2026-10-10
Generated By	AI Security Engineer (author)
Method/Tool	Manual inventory against the deployed AgentCore resources (get-harness, get-gateway, IAM policy snapshots in iam/before/ and the capture files in evidence/) and vendor documentation, assembled with

Field	Value
	tools/fill_templates.py from content/mlbom.yaml. Structure follows the CycloneDX ML-BOM concepts in the course template.

Model A – 1.2 Other References (Optional)

Reference Type	URL/Link
Paper	Claude Haiku 4.5 System Card (Anthropic): https://www.anthropic.com/claude-haiku-4-5-system-card
Website	https://www.anthropic.com/claude/haiku
Documentation	https://docs.aws.amazon.com/bedrock/latest/userguide/models-supported.html
Contact	Anthropic Trust Center: https://trust.anthropic.com

Model A – 1.3 Tags (Optional)

text-generation, tool-use, agent, RAG answer generation, proprietary, managed API, Amazon Bedrock, Anthropic, cross-Region inference profile

---

Model A – 2. Model Architecture

Model A – 2.1 Training Datasets

Dataset Name	Source URL	License	Usage Notes
Not itemized by the vendor	https://www.anthropic.com/claude-haiku-4-5-system-card	Proprietary	**FINDING F-01.** Anthropic gives only a high-level description: public web data (collected following site operators' robots.txt instructions), licensed third-party data, data from labeling services and

Dataset Name	Source URL	License	Usage Notes
			contractors, data from users who opted in to training, and synthetic data. The datasets, volumes, proportions and cutoff-date coverage are not disclosed, so provenance, licensing and contamination cannot be audited.

Model A – 2.2 Architecture Details

Field	Value
Architecture	Decoder-only transformer (autoregressive LLM) with native tool use. Layer count, parameter count and training recipe are not published.
Architecture Family	Anthropic Claude 4.5 family, Haiku tier

Model A – 2.3 Model Lineage

Relationship	Model Name	Version	Source URL
Parent Model	Not disclosed by the vendor		
Base Model	Not disclosed. Pretrained by Anthropic and not fine-tuned by Northstar		

Model A – 2.4 Input/Output

Field	Value
Input	Text: the system prompt, user turns and tool results (retrieved knowledge base passages returned by the Gateway Retrieve tool). The model also accepts images, which Northstar Assist does not use.

Field	Value
Output	Text answers and tool calls (Retrieve invocations carrying a search query). Output is non-deterministic and streamed to the harness.

Model A – 2.5 Hardware & Software (Optional)

Category	Details
Hardware	Not exposed. Amazon Bedrock hosts the model. The US cross-Region profile may serve a request from us-east-1, us-east-2 or us-west-2 at the time of writing, so prompts can leave the calling Region within the US.
Software	Amazon Bedrock Runtime (Converse API) behind the Amazon Bedrock AgentCore Harness. No local runtime or libraries.

Model A – 2.6 Software Required for Execution

Field	Value
Includes Executable Code	False
Additional Dependencies	None shipped. Runtime dependencies are the Bedrock inference profile, the AgentCore Harness and an IAM role allowing bedrock:InvokeModel on that profile.

Model A – 3. Usage

Model A – 3.1 Intended Use

Answer questions from Northstar employees about company policies, procedures, product documentation, engineering notes and operational runbooks, using only passages retrieved from the Northstar knowledge base, and name the source document in each answer. The agent is read-only: it retrieves and explains, it takes no actions on other systems.

Known limitations that the deployment must compensate for: the model can hallucinate when retrieval is empty or weak (the system prompt requires a citation and the guardrail applies contextual grounding); it is susceptible to prompt injection, direct and through retrieved text; its knowledge has a cutoff (the Amazon Bedrock model card lists February 2025), so answers outside the knowledge base may be out of date; and output is non-deterministic, so the same question can produce different answers across runs.

Model A – 3.2 Out of Scope Usage

Legal, medical or investment advice; decisions about individual employees (hiring, performance, compensation); answering questions about other employees' salaries or personal data; producing bulk exports of the employee directory, customer contacts, revenue or pipeline figures.

Handling credentials or secrets, taking actions on other systems, customer-facing use, use with data above the Confidential classification, general-purpose assistance unrelated to Northstar, and being the only authority for security or disaster-recovery procedures without human confirmation.

Model A – 3.3 Misuse or Malicious Use

Direct prompt injection or jailbreaks to override the system prompt, expose it or change the persona; multi-turn evasion that builds toward a blocked request over several innocuous turns; and indirect injection through instructions planted in a knowledge base document.

Systematic enumeration of the employee directory, customer contacts, deal sizes or department salary budgets through repeated questions; extracting the model's behaviour by bulk querying; and abuse of the agent as free compute through very long inputs or forced tool loops, which also drives up cost.

Model B: Amazon Titan Text Embeddings V2 (embedding model)

Model B turns text into vectors. The Managed KB invokes it to embed document chunks at ingestion time and the user's search query at retrieval time, so it decides which passages count as relevant. It is not generative and is never called by the harness directly.

Model B – 1. Model Information

Field	Value
Name	Amazon Titan Text Embeddings V2
Version	v2:0 (Bedrock model ID suffix :0)
Type	embeddings: text encoder that maps text to a fixed-length float vector (not generative)
Author	Amazon Web Services (Amazon Titan model family)
Licenses	Proprietary. AWS Customer Agreement and AWS Service Terms apply through Amazon Bedrock. No weights are distributed.
Libraries	N/A (managed API; no libraries or weights are shipped to Northstar)
Source URL	https://docs.aws.amazon.com/bedrock/latest/userguide/titan-embedding-models.html
Model ID	amazon.titan-embed-text-v2:0

Field	Value
Access path	Invoked by the Managed Knowledge Base under its service role; never by the harness or the user
Maximum input	8,192 tokens per text
Output dimensions	1024 (default); 512 and 256 are selectable. Vectors can be normalized.

Model B – 1.1 BOM Generation (Optional)

Field	Value
Generated Date	2026-10-10
Generated By	AI Security Engineer (author)
Method/Tool	Manual inventory against the deployed Managed Knowledge Base configuration and AWS documentation for the Titan embedding models, assembled with tools/fill_templates.py from content/mlbom.yaml.

Model B – 1.2 Other References (Optional)

Reference Type	URL/Link
Paper	No paper for this model has been published. See the AWS Titan embeddings documentation.
Website	https://aws.amazon.com/bedrock/amazon-models/titan/
Documentation	https://docs.aws.amazon.com/bedrock/latest/userguide/titan-embedding-models.html
Contact	AWS Support, and the AWS Responsible AI resources: https://aws.amazon.com/ai/responsible-ai/resources/

Model B – 1.3 Tags (Optional)

embeddings, semantic search, RAG retrieval, encoder, 1024-dimension, proprietary, managed API, Amazon Bedrock, Amazon Titan

Model B – 2. Model Architecture

Model B – 2.1 Training Datasets

Dataset Name	Source URL	License	Usage Notes
Not itemized by the vendor	https://docs.aws.amazon.com/bedrock/latest/userguide/titan-embedding-models.html	Proprietary	**FINDING F-02.** AWS describes the training data only in general terms. No dataset list, volumes, licences or provenance are published, so training-data licensing, contamination and any memorized content cannot be audited.

Model B – 2.2 Architecture Details

Field	Value
Architecture	Transformer-based text encoder that outputs one embedding per input text. Layer and parameter counts are not published.
Architecture Family	Amazon Titan Embeddings

Model B – 2.3 Model Lineage

Relationship	Model Name	Version	Source URL
Parent Model	Not disclosed by the vendor		
Base Model	Not disclosed. Part of the Amazon Titan Embeddings line, not fine-tuned by Northstar		

Model B – 2.4 Input/Output

Field	Value
Input	Text up to 8,192 tokens: document chunks produced by the KB ingestion

Field	Value
	job, and the search query sent by the Retrieve tool.
Output	A normalized float vector with 1024 dimensions (configurable to 512 or 256). No text is generated.

Model B – 2.5 Hardware & Software (Optional)

Category	Details
Hardware	Not exposed. Amazon Bedrock hosts the model in the Region of the knowledge base (us-east-1).
Software	Amazon Bedrock Runtime InvokeModel, called by the Managed Knowledge Base service. No local runtime or libraries.

Model B – 2.6 Software Required for Execution

Field	Value
Includes Executable Code	False
Additional Dependencies	None shipped. Runtime dependency is the KB service role AmazonBedrockExecutionRoleForKnowledgeBase_x7ne0, which must be allowed bedrock:InvokeModel on this model only.

Model B – 3. Usage

Model B – 3.1 Intended Use

Convert Northstar document chunks and employee questions into vectors so the Managed Knowledge Base can rank passages by semantic similarity and return the closest ones to the agent. The same model must be used for ingestion and for queries; vectors from different models or dimensions cannot be compared.

Known limitations: similarity is not authorization, so the closest chunks are returned regardless of who is asking or how sensitive the chunk is; retrieval quality depends on chunking and on how closely the query wording matches the documents; and vectors are not encryption, because text can be partially reconstructed from embeddings.

Model B – 3.2 Out of Scope Usage

Any decision that needs an access-control check (for example deciding which documents a user may see), text classification or PII detection, and embedding data from outside the Northstar knowledge base.

Use as a security control or as a source of truth. Changing the model or the output dimension without re-indexing the whole knowledge base is also out of scope, because it silently breaks retrieval.

Model B – 3.3 Misuse or Malicious Use

Poisoning the corpus with documents written to sit close to common questions so that they are retrieved ahead of legitimate sources, and using that position to deliver injected instructions.

Attempting embedding inversion on stolen vectors or chunk text, probing retrieval with crafted queries to learn what the corpus contains, and using the embedding API as a free general-purpose compute service.

---

4. Supporting Components and IAM Roles

The components below are not models, but they decide what data the models see, who can reach them and what is recorded. Each row states what the component is, the failure mode that matters for security, and what the vendor or the deployment does not tell us. IAM roles are listed by name because the console-generated default roles are the main privilege-escalation surface.

Component	Type	Provider	Intended use	Security failure mode	Limitations / transparency gaps
Knowledge corpus: 30 synthetic documents	Data (RAG source): csv, docx, html, pdf, txt and xlsx files	Udacity sample data (synthetic), copied unchanged by the project owner	Ground the agent's answers in Northstar policies, runbooks, product and operations documents.	Contains personal and business data that a bulk question could expose: employee names, work emails, phone extensions, titles and locations; third-party customer contact names and emails; monthly revenue and deal sizes; department salary budgets. Disaster-recovery plan, quarterly review and security policy are labelled Confidential. A document containing instructions would be read by the model as context. No SSNs, card numbers or credentials were found.	Synthetic, so no real person is affected, but it is shaped like real data. There is no per-document access control or classification enforcement at retrieval time. Content is static and may be outdated.
S3 bucket northstar-assist-kb-5ca661ad	Object storage (source of truth for the KB)	AWS (Amazon S3), owned by Northstar	Hold the 30 documents; the Managed KB reads them during ingestion.	Write access is write access to the agent's knowledge: a malicious or edited object becomes retrievable after the next sync (poisoning). Public access or an over-broad bucket policy would expose every document.	Public access blocked, SSE-S3 (AWS-managed keys, not customer-managed), versioning on. No object-level classification tags or integrity hashes are checked at sync time.

Component	Type	Provider	Intended use	Security failure mode	Limitations / transparency gaps
Managed Knowledge Base WUWHZC06MP	Retrieval service (ingestion, chunking, embedding, search)	AWS (Amazon Bedrock Managed Knowledge Bases)	Parse the documents, embed chunks with Model B and answer Retrieve calls from the Gateway.	Returns the most similar chunks whoever asks, so any caller of the Gateway can read any ingested chunk. Retrieved text is returned to the model without any prompt-attack inspection. A sync with poisoned input changes answers.	Chunking, ranking and parsing behaviour are service defaults with limited tuning. Retrieval results are not signed and carry no access-control metadata.
Managed KB vector store	Vector database (managed by the KB service)	AWS	Store 1024-dimension chunk embeddings and chunk text for similarity search.	Holds an embedded copy of all document text, including the personal data above. Embeddings can be partially inverted to text. Deletion of a source object does not remove its vectors until the next sync.	**Transparency gap (F-03).** The storage engine, index configuration, encryption key and network exposure of the managed store are not disclosed and not configurable, so these properties cannot be verified or pinned in this ML-BOM.
AgentCore Gateway arn:aws:bedrock-agentcore:us-east-1:609617804976:gateway/northstar-assist-gateway-hd1uvsa8f3	Tool gateway (MCP) with the Managed KB as a target	AWS (Amazon Bedrock AgentCore)	Expose the KB Retrieve operation to the harness as an MCP tool, with IAM (SigV4) inbound authorization.	Any principal with invoke permission on the Gateway can query the whole corpus. The harness trusts tool responses it receives; a spoofed or tampered target response would feed the model attacker-controlled text. All callers appear as the harness execution role, so there is no per-user attribution.	Authorization is by IAM caller only. Request and response payloads are not logged unless logging is enabled, and the gateway offers no content inspection of tool results.
AgentCore Harness arn:aws:bedrock-agentcore:us-east-1:609617804976:harness/NorthstarAssist-XSASd9gyWX	Managed agent runtime (agent loop)	AWS (Amazon Bedrock AgentCore)	Run Model A with the system prompt, memory off and the Gateway tool; return streamed answers.	Excessive agency: the model decides how many tool calls to make, so a looped or inflated prompt can multiply cost. The system prompt is stored in the harness configuration and readable by anyone with permission to read it. One IAM caller represents all users.	The agent loop implementation is a managed service whose internals are not published. Memory is disabled, so conversation state exists only within a session.
Bedrock Guardrail arn:aws:bedrock:us-east-1:609617804976:guardrail/753a9dgwqe2f	Safety filter on model input and output	AWS (Amazon Bedrock Guardrails)	Block prompt attacks and denied topics, filter harmful content, mask or block sensitive information, and check grounding.	The prompt-attack filter inspects user input only; it does not inspect retrieved chunks returned as tool results (F-07). Filters are probabilistic, so multi-turn and obfuscated attacks can pass. Masking personal data in output does not stop bulk disclosure of non-masked categories.	Classifier internals, training data and error rates are not published, so thresholds must be validated empirically against the red-team suite.
Streamlit chat client (streamlit_app)	Client application	Northstar project code (open-source Streamlit framework)	Give employees a chat UI and show monitoring views for administrators.	A single shared password protects the app and every request reaches AWS as the same IAM caller, which defeats attribution (repudiation). Credentials in the environment of the host are the real trust anchor.	No per-user identity, session binding or rate limiting beyond what the harness enforces.
CloudWatch Logs and Bedrock	Observabilit	AWS (Amazon	Record prompts, responses, guardrail	Invocation logs store the full prompt and response	Retention is short (7 days) to limit cost and exposure,

Component	Type	Provider	Intended use	Security failure mode	Limitations / transparency gaps
model-invocation logging	y and audit	CloudWatch , Amazon Bedrock)	actions and token usage for monitoring, alarms and incident response.	text, so every retrieved chunk containing personal data is copied into a second store with its own retention and access rules (F-05). Access to the log group is effectively access to the corpus.	which also limits forensic history. The harness runtime log format is not a documented contract.
IAM role AmazonBedrockAgentCoreHarnessDefaultServiceRole-37uao	Harness execution role (console-generated default)	AWS-generated, owned by Northstar	Let the harness call Bedrock models, the Gateway and CloudWatch Logs.	The default policy is broader than needed (wide model and resource scope). A prompt-injected agent acts with every permission the role has (elevation of privilege, F-04).	The generated policy text is set by the console and can change between console versions. The scoped replacement must be re-verified after any harness update.
IAM role AmazonBedrockAgentCoreGatewayDefaultServiceRole1791659264711	Gateway service role (console-generated default)	AWS-generated, owned by Northstar	Let the Gateway call the Managed KB Retrieve operation.	Default scope can cover knowledge bases and other resources beyond the one target, allowing the gateway to be pointed at unintended data (F-04).	Same limitation as the harness role: generated policy, not versioned by AWS.
IAM role AmazonBedrockExecutionRoleForKnowledgeBase_x7ne0	Knowledge base service role (console-generated)	AWS-generated, owned by Northstar	Read objects from the bucket, call Model B and write to the managed vector store.	Read access to the whole bucket, so every object that is written there can be ingested. Permission to invoke Model B must not extend to other models.	Permissions for the managed vector store are service-internal and cannot be audited from the role alone.
IAM role NorthstarBedrockInvocationLoggingRole	Logging role created by this project	Northstar (project-defined)	Let Bedrock write model-invocation logs to the dedicated CloudWatch log group.	Trust policy not restricted to bedrock.amazonaws.com and the account (confused deputy), or write access beyond the one log group, would let others redirect or tamper with audit records.	Limited to logs:CreateLogStream and logs:PutLogEvents on one log group. It cannot read logs, so investigation uses separate read permissions.

5. Findings

The findings below are transparency gaps and risks that remain after the ML-BOM is complete. They feed the STRIDE-ML threat model and the launch-readiness decision; none of them can be closed by Northstar alone unless noted.

F-01: Training data for Model A (Claude Haiku 4.5) is not disclosed in detail (Medium)

Anthropic describes the data only at a high level (public web data, licensed data, labeling-service data, opted-in user data and synthetic data). The sources, proportions and filtering are not published, so provenance, copyright status, contamination with personal data and memorization cannot be audited.

Action: Accept as a supply-chain risk, record the vendor system card as the evidence, rely on compensating controls (output filtering, contextual grounding) and re-review when the vendor publishes a new model card.

F-02: Training data for Model B (Titan Text Embeddings V2) is not disclosed (Medium)

AWS gives only a general description. Licensing, provenance and any bias in the vector space are unknown, which can skew which passages are retrieved.

Action: Accept and monitor. Evaluate retrieval quality on Northstar questions (the red-team suite includes grounding checks) and keep the model ID and dimension pinned in the KB configuration.

F-03: The Managed KB vector store engine and settings are not disclosed (Medium)

The storage engine, index parameters, encryption key and network exposure of the managed vector store cannot be inspected or configured. Embedded copies of every document, including personal data, live there.

Action: Treat the store as containing the full corpus, apply the same data classification as the source bucket and delete the KB (and its vectors) at the end of the exercise.

F-04: Console-generated default IAM roles are broader than the workload needs (High)

The harness execution role and the Gateway role are created by the console with wide scopes (models, knowledge bases, logs). An injected agent could use any permission the role holds.

Action: Replace the policies with scoped inline policies limited to the Haiku 4.5 inference profile, the one Gateway, the one guardrail and the one knowledge base, and prove the result with policy simulation.

F-05: Model-invocation logs copy retrieved personal data into CloudWatch (High)

Full prompts and responses are stored, so employee and customer details retrieved from the corpus are duplicated in a second location with separate retention and access.

Action: Restrict read access to the log group, keep retention short (7 days) and treat log access as access to the corpus. Consider disabling text logging for production if the monitoring use case allows it.

F-06: The corpus contains personal and confidential business data with no retrieval-time access control (High)

Retrieval is by similarity, not by authorization. Any employee who can ask can ask for employee contacts, customer contacts, revenue, deal sizes or salary budgets, and the most relevant chunks are returned.

Action: Add denied topics and sensitive-information policies in the guardrail, a system prompt rule to refuse bulk listing, and monitoring for enumeration patterns. Longer term, filter retrieval by caller entitlement.

F-07: The guardrail prompt-attack filter does not inspect retrieved passages (High)

Instructions hidden in a knowledge base document arrive as a tool result and are not evaluated by the prompt-attack filter. Indirect prompt injection therefore depends on the system prompt and on output filtering.

Action: Harden the system prompt (retrieved text is data, never instructions), control who can write to the bucket, and add a post-retrieval inspection hook as a compensating control where the platform allows it.

F-08: Cross-Region inference can process prompts outside the calling Region (Low)

The US inference profile may route a request to us-east-1, us-east-2 or us-west-2. The prompt, including retrieved passages, can therefore be processed in a Region other than the one where the data is stored.

Action: Accept for synthetic data, and record the destination Regions in the IAM policy. Re-evaluate for real data-residency requirements.

F-09: Vendor-managed models can be retired or updated outside Northstar's change process (Medium)

Both models are managed APIs with a vendor lifecycle. Behaviour is pinned by the dated model ID but not indefinitely, and there are no weights to archive for reproducibility. This is concrete for the foundation model: the Bedrock model card for Claude Haiku 4.5 gives "EOL no sooner than 16 Oct 2026", eight days after this assessment, and a successor (Claude Haiku 5.5) is already listed. A forced migration would change behaviour that the guardrail and red-team results were validated against.

Action: Pin the exact model IDs, subscribe to Bedrock deprecation notices, plan the successor model now (check that it supports Guardrails and tool use on the bedrock-runtime endpoint), update the scoped IAM model ARNs, and re-run the full red-team suite before switching. This is a launch condition.

Attestation

Role	Name	Date
Author	AI Security Engineer (author)	2026-10-10
Reviewer	Security Lead (reviewer), signature pending	Pending

References

- CycloneDX ML-BOM Specification
- SPDX AI/ML Profile
- NIST AI Risk Management Framework